

this standard is designed to accomplish. This clause and the subsequent FR-specific clauses furnish the normative material necessary to build extensions to existing enterprise security to support the rigorous integrity and availability requirements needed by IACS.

NOTE The contents of this clause will eventually be incorporated into IEC 62443-1-1.

4.2 Support of essential functions

As documented in 3.1.22, an essential function is a “function or capability that is required to maintain health, safety, the environment and availability for the equipment under control.”

- Security measures shall not adversely affect essential functions of a high availability IACS unless supported by a risk assessment.

NOTE See IEC 62443-2-1 regarding the documentation requirements associated with the risk assessment required to support instances where security measures may affect essential functions.

When reading, specifying and implementing the SRs described in this standard, implementation of security measures should not cause loss of protection, loss of control, loss of view or loss of other essential functions. After a risk analysis, some facilities may determine certain types of security measures may halt continuous operations, but security measures shall not result in loss of protection that could result in health, safety and environmental (HSE) consequences. Some specific constraints include:

- Access Controls (IAC and UC) shall not prevent the operation of essential functions, specifically:
 - Accounts used for essential functions shall not be locked out, even temporarily (see 5.5, SR 1.3 – Account management, 5.6, SR 1.4 – Identifier management, 5.13, SR 1.11 – Unsuccessful login attempts and 6.7, SR 2.5 – Session lock).
 - Verifying and recording operator actions to enforce non-repudiation shall not add significant delay to system response time (see 6.14, SR 2.12 – Non-repudiation).
 - For high availability control systems, the failure of the certificate authority shall not interrupt essential functions (see 5.10, SR 1.8 – Public key infrastructure (PKI) certificates).
 - Identification and authentication shall not prevent the initiation of the SIF (see 5.3, SR 1.1 – Human user identification and authentication and 5.4, SR 1.2 – Software process and device identification and authentication). Similarly for authorization enforcement (see 6.3, SR 2.1 – Authorization enforcement).
 - Incorrectly timestamped audit records (see 6.10, SR 2.8 – Auditable events and 6.13 SR 2.11 – Timestamps) shall not adversely affect essential functions.
- Essential functions of an IACS shall be maintained if zone boundary protection goes into fail-close and/or island mode (see 9.4, SR 5.2 – Zone boundary protection).
- A denial of service (DoS) event on the control system or safety instrumented system (SIS) network shall not prevent the SIF from acting (see 11.3, SR 7.1 – Denial of service protection).

4.3 Compensating countermeasures

Compensating countermeasures, as used in this standard, shall adhere to the guidelines described in IEC 62443-3-2.

Throughout this standard, the SR normative language states that “the control system shall provide the capability to...” support some specific security requirement. The control system shall provide the capability, but it might be performed by an external component. In such a case, the control system shall provide an ‘interface’ to that external component. Some examples of compensating countermeasures include user identification (including centralized versus distributed), password strength enforcement, signature validity checking, security event correlation and device decommissioning (information persistence).